SECURITY-FIRST MCP / JAVA 21

Secure MCP Integration Gateway

Ein kontrollierter Sidecar zwischen AI Clients und Connector Hub: identitätsbasierte Mandantentrennung, Least Privilege, exakte Human Approval, Credential Separation und ausführbare Angriffsevidenz.

Release candidate 1.0.0-rc.1

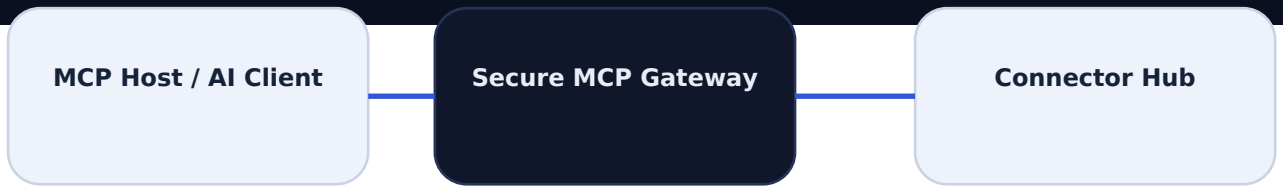
26	40	11	77
Java Contracts	HTTP/MCP Angriffe	Release Checks	verifiziert gesamt

Stand 2026-10-12 · Portfolio Engineering Release

01 / ARCHITEKTUR

Autorität bleibt außerhalb des Modells

Connector Hub führt Provider aus; das Gateway kontrolliert AI-seitige Identität, Tenant, Policy, Approval und Audit.



- Tenant aus verifizierter Identität - nie Modellargument
- Scope-gefilterte Tool Discovery + Authorization beim Call
- Eigenes Connector-Hub-Service-Credential; kein Token-Passthrough
- Feste Upstream-Pfade + HTTPS/Host-Allowlist
- Quoten, Approval State und manipulationsnachweisbares Audit

02 / CAPABILITY SURFACE

Bewusst klein

Drei Reads und ein konsequenter Write. Kein beliebiges SQL. Kein benutzergesteuertes Ziel.

Tool	Scope	Effekt	Approval
orders.lookup	orders:read	Order lesen	Nein
inventory.check	inventory:read	Bestand lesen	Nein
customer.documents.list	documents:read	Erlaubte Dokumente	Nein
orders.cancel	orders:cancel	Order stornieren	Unabhängig

MCP 2026-07-28 focused subset

server/discover, tools/list, tools/call; per-request Metadaten; Method/Name Header Binding; aktuelle Result/Cache-Felder; Protected Resource Metadata. Tool-Sichtbarkeit ist authorization-sensitiv, daher ist tools/list private-cache scoped.

03 / GOVERNED WRITE

Approval bindet die exakte Aktion

Eine Human Approval ist kein wiederverwendbarer Capability Token.

1. Operator/Modell schlägt orders.cancel vor
2. Gateway kanonisiert Business-Argumente
3. Approval speichert Tenant + Requester + Tool-Revision + SHA-256-Argument-Fingerprint
4. Unabhängiger Reviewer im selben Tenant genehmigt
5. Execution rekonstruiert und prüft alle Bindungsfelder erneut
6. Approval-ID wird zum Upstream-Idempotency-Key

TAMPER-TEST

Ein Zeichen in der genehmigten Begründung ändern, Requester/Tenant wechseln oder Tool-Revision ändern: Execution schlägt mit approval_binding_mismatch geschlossen fehl.

04 / ADVERSARIAL EVIDENCE

Zum Angreifen gebaut

Das Portfolio-Signal ist nicht der Happy Path, sondern die Denial-Fläche.

PASS	Wrong-Audience, abgelaufene und manipulierte Tokens
PASS	Cross-Tenant Order-, Dokument- und Approval-Zugriff
PASS	Beliebiges SQL und Destination/URL-Injection
PASS	MCP Protocol/Header/Name-Mismatch
PASS	Self-Approval, Cross-Tenant-Review und Argument-Tampering
PASS	Duplicate Execution und Concurrency/Idempotency
PASS	Audit-Kettenintegrität und keine rohen Business-Argumente
PASS	Quota Enforcement pro Principal/Tool

05 / RELEASE EVIDENCE

77 deterministische Checks bestanden

Lokal verifiziert; zusätzliche Interoperabilitäts-Gates bleiben separat.

26	40	11
Java contracts	live HTTP/MCP attacks	repository/release checks

NICHT ALS LOKAL BESTANDEN BEHAUPTET

Native Playwright Reviewer-Console-Akzeptanz; offizieller stabiler MCP TypeScript v2 Client; echte Connector-Hub-Provider-Akzeptanz. Sie sind explizite Release-Gates und keine versteckten Lücken.

06 / DELIVERY

Bereit für GitHub Review

Standalone Sidecar; geänderte bestehende Connector-Hub-Dateien: 0.

- Java-21-Source + synthetisches Demo-Backend
- Connector-Hub-HTTP-Adapter mit festem Provider-Mapping
- 40-Szenario-Angriffsmatrix + Java Contracts
- Reviewer-Konsole mit strikter CSP
- Technische Dokumentation Englisch/Deutsch
- GitHub CI + separate Browser/Official-SDK-Gates
- LinkedIn-Publishing-Pack + Release Dossier

Primäre Referenzen

ts.sdk.modelcontextprotocol.io/v2/
modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations
github.com/AhadPorkar/connector-hub